AWESOME ATLAS

เว็บค้นพบโอเพนซอร์สจาก GitHub Awesome lists ผ่าน awesome-api

NFR และความปลอดภัย

รหัสเอกสาร	AWE-DOC-03
ฉบับ	0.1
วันที่	2026-10-07
สถานะ	ร่างเพื่อพิจารณา

เอกสารภายในฉบับร่าง — ใช้ประกอบการพัฒนาและดูแลระบบ

สารบัญ

Performance

Availability

Scalability

Security controls

Privacy/PDPA

Observability

Backup/DR

เป้าหมายที่วัดได้

การอนุมัติ

แหล่งข้อมูล

Awesome Atlas Web — NFR และความปลอดภัย

Performance

- asset ที่มี hash ใน `/assets/*` ตั้ง `Cache-Control: public, max-age=31536000, immutable`; หน้า HTML `no-cache`
- บีบอัด `zstd gzip` ที่ Caddy
- ฟอนต์ self-host ผ่าน fontsource และ avatar เป็นตัวอักษร ไม่พึ่ง remote images

Availability

- หนึ่ง replica และปิด app sleeping บน Railway; ยังไม่มี SLA ที่กำหนด **[ต้องยืนยัน]**
- เมื่อซิงก์ผิดพลาด UI ยังแสดง projection ล่าสุดพร้อมสถานะ (ตาม `DESIGN.md`)

Scalability

- เว็บเป็น static ขยาย replica ได้ง่าย แต่ API ต้องเป็น writer เดียวต่อ volume (ห้ามเพิ่ม API replica)

Security controls

- Header จาก Caddy: `X-Content-Type-Options nosniff`, `X-Frame-Options DENY`, `Referrer-Policy strict-origin-when-cross-origin`
- ไม่มี Content-Security-Policy ใน `Caddyfile` **[ต้องยืนยัน]** ว่าต้องเพิ่มหรือไม่
- Caddy `admin off`; image รันเป็น non-root UID 10001
- `Dockerfile.dockerignore` แบบ allowlist ส่งเฉพาะ build inputs ของเว็บเข้า image
- browser ไม่ได้รับ credentials ใด ๆ และทั้งสอง service ไม่มี provider token (ตาม deployment README)
- บุ๊กมาร์กที่อ่านจาก `localStorage` ถูก validate รูปแบบ repo id และตัดที่ 200 รายการ (`src/state.ts`)

Privacy/PDPA

- ไม่มี login และไม่เก็บข้อมูลส่วนบุคคลฝั่งเซิร์ฟเวอร์จากเว็บ บุ๊กมาร์กอยู่ในเครื่องผู้ใช้
- access log ของ Caddy/Railway อาจมี IP ผู้ใช้ **[ต้องยืนยัน]** นโยบาย retention ของ log
- ไม่พบ analytics หรือ cookie ในโค้ดที่ตรวจ

Observability

- `/health` (web process) และ `/api/v1/status` (`last_synced_at`, รอบซิงก์, error ของแหล่ง)
- UI แสดงเวลาซิงก์และเตือนเมื่อข้อมูลเกิน 24 ชั่วโมง
- ไม่มี error tracking/metrics ฝั่ง frontend **[ต้องยืนยัน]**

Backup/DR

- เว็บไม่มีสถานะ กู้คืนได้จาก Dockerfile/image เดิม
- ข้อมูลของ API บน volume ยังไม่มี managed backup หรือ retention (ตาม deployment README) — ความเสี่ยงอยู่ที่ `awesome-api`

เป้าหมายที่วัดได้

ID	เป้าหมาย	วิธีวัด	สถานะ
NFR-01	`/health` ตอบ 200	ตรวจหลัง deploy	มีหลักฐานใน deployment README
NFR-02	ข้อมูลไม่เก่ากว่า 24 ชั่วโมง	`last_synced_at` จาก `/api/v1/status`	UI เตือนเมื่อเกิน
NFR-03	asset ที่มี hash cache 1 ปีแบบ immutable	ตรวจ response header	ตั้งใน `Caddyfile`
NFR-04	ไม่มีค่าลับใน bundle/image	ตรวจ allowlist และ bundle	allowlist มีอยู่
NFR-05	Availability/latency เป้าหมาย	—	**[ต้องยืนยัน]**

การอนุมัติ

บทบาท	สถานะ	วันที่	ลงนาม
Solution Architect	รอพิจารณา	—	_
Security	รอพิจารณา	—	_

แหล่งข้อมูล

- `apps/awesome-web/Caddyfile`, `apps/awesome-web/Dockerfile`, `apps/awesome-web/DESIGN.md`, `apps/awesome-web/src/state.ts`
- `services/awesome-api/deployment/README.md`